Informe de Seguridad: Mass Assignment — Manipulación del Descuento

1. Título

Mass Assignment en el proceso de checkout permite manipular el porcentaje de descuento.

2. Descripción

Durante la evaluación del laboratorio *Exploiting a mass assignment vulnerability* de PortSwigger Web Security Academy, se investigó el comportamiento del endpoint `POST /api/checkout`.

Al analizar la respuesta de la API, se identificó el objeto `chosen_discount`, que contenía la propiedad `percentage` con un valor inicial de `0`. La respuesta también incluía información sobre los productos seleccionados, sus cantidades y sus precios.

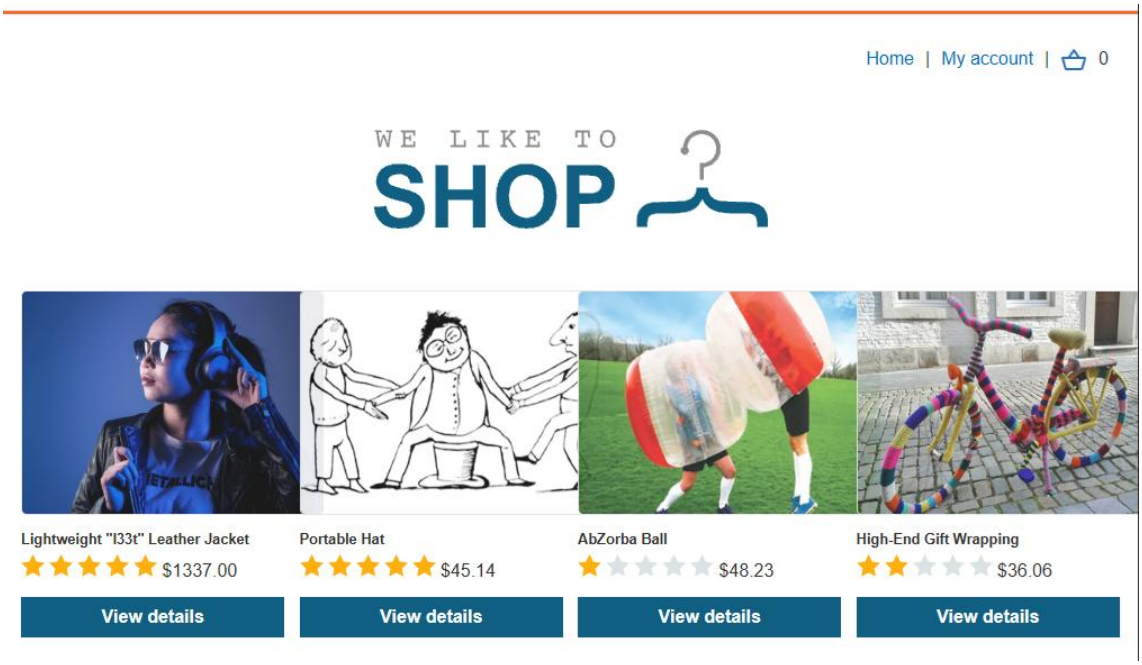
A partir de esta observación, se formuló la hipótesis de que la aplicación podría aceptar valores de descuento controlados por el cliente. La hipótesis se comprobó modificando la solicitud en Burp Suite Repeater.

El laboratorio confirmó la resolución después de la prueba, lo que demuestra que la manipulación del descuento fue aceptada en el entorno controlado.

3. Evidencia

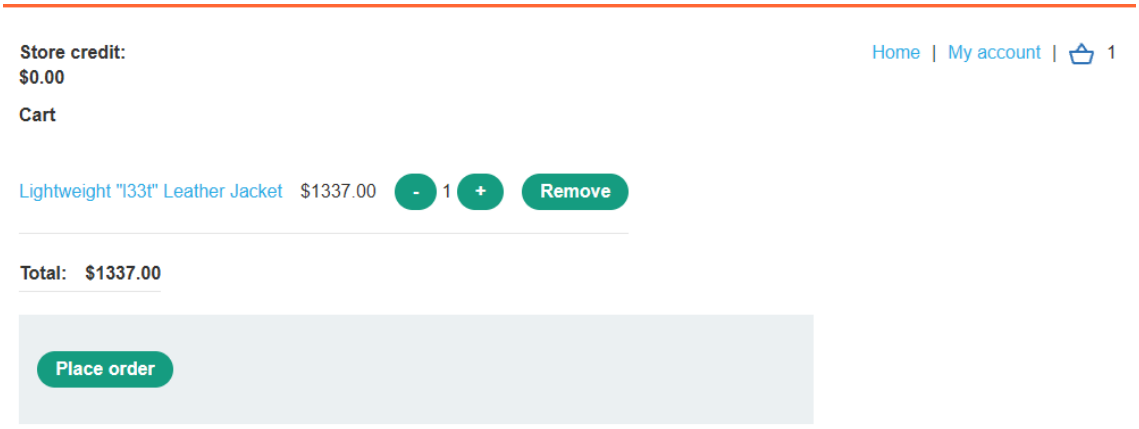
Evidencia 1 — Página inicial

Se documentó el estado inicial de la tienda antes de realizar las pruebas.



Evidencia 2 — Producto seleccionado

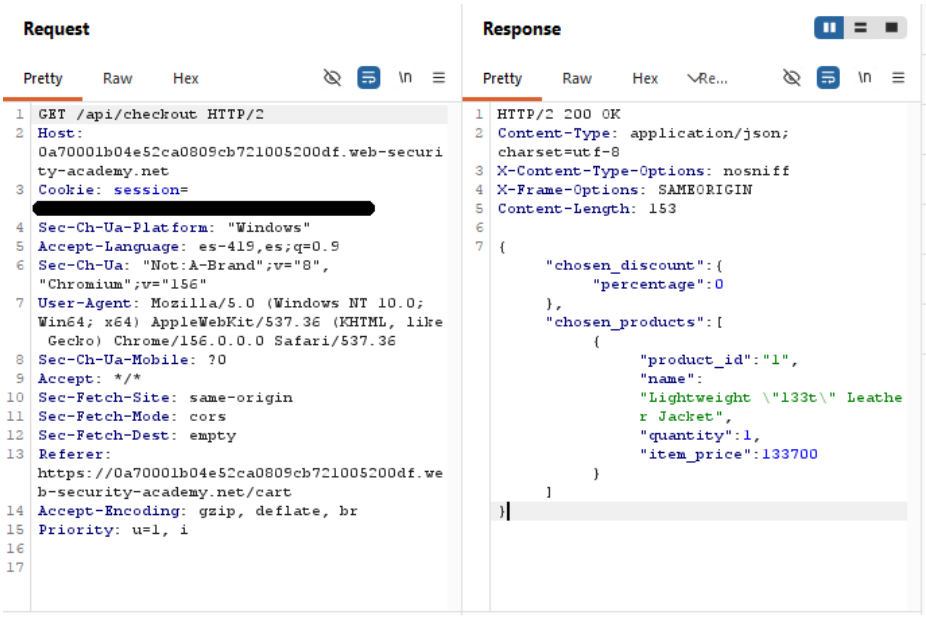
Se documentó el producto utilizado durante la prueba.



Evidencia 3 — Respuesta original de la API

La respuesta de `POST /api/checkout` expuso el objeto `chosen_discount` con `percentage: 0`, junto con los datos de los productos seleccionados.

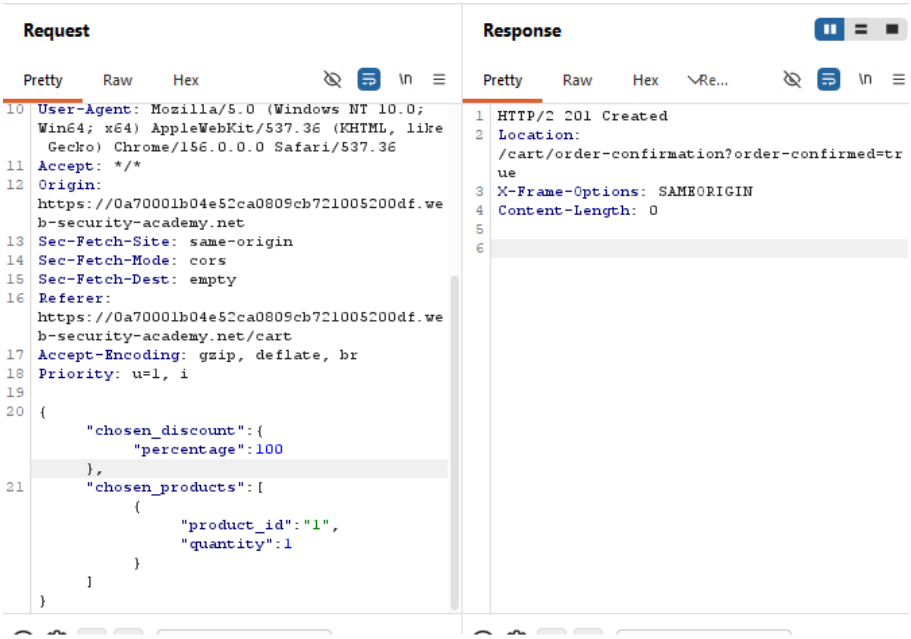
Esta información permitió identificar una propiedad candidata para investigar una posible vulnerabilidad de Mass Assignment.



Evidencia 4 — Solicitud modificada y respuesta del servidor

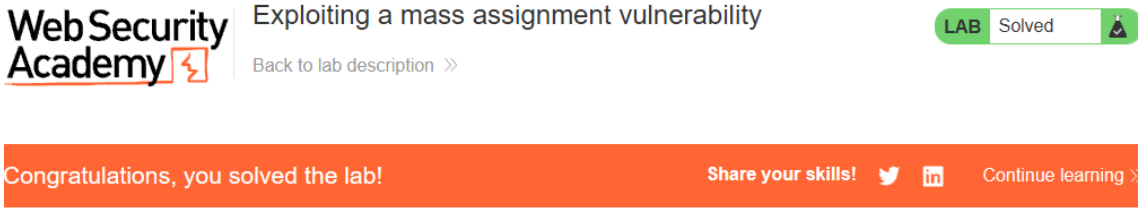
Se modificó la solicitud de checkout mediante Burp Suite Repeater para probar si el porcentaje de descuento podía ser controlado desde el cliente.

La respuesta del servidor indicó `201 Created` y devolvió la ruta `/cart/order-confirmation?order-confirmed=true`. Posteriormente, PortSwigger marcó el laboratorio como resuelto.



Evidencia 5 — Resolución del laboratorio

La plataforma PortSwigger Web Security Academy mostró el estado `Solved`, confirmando que se cumplió el objetivo del laboratorio.



4. Impacto (CIA)

Confidencialidad (C): no se identificó un impacto directo sobre la confidencialidad de los datos durante la prueba.

Integridad (I): la manipulación de una propiedad relacionada con los descuentos puede alterar el importe de una transacción y permitir condiciones comerciales no autorizadas.

Disponibilidad (A): no se identificó un impacto directo sobre la disponibilidad del servicio.

Impacto de negocio: si el comportamiento estuviera presente en un sistema real, podría provocar descuentos no autorizados, pérdidas económicas y alteraciones en el procesamiento de pedidos.

5. Causa raíz

La causa raíz consiste en un control insuficiente sobre las propiedades que el cliente puede influir durante el procesamiento del checkout.

La aplicación permitió que el valor de `chosen_discount.percentage` afectara el procesamiento del pedido, en lugar de calcular y validar el descuento exclusivamente mediante lógica confiable del lado del servidor.

Este comportamiento es consistente con una vulnerabilidad de **Mass Assignment (asignación masiva)**, en la que propiedades controladas por el cliente pueden modificar atributos internos de un objeto sin restricciones adecuadas.

6. Remediación

- Calcular los descuentos exclusivamente del lado del servidor.
- No confiar en valores de precios o descuentos proporcionados por el cliente.
- Definir una lista permitida de propiedades aceptadas para cada endpoint.
- Validar los tipos, rangos y permisos de los datos recibidos.
- Calcular el importe final usando precios y reglas comerciales almacenados o verificados en el servidor.
- Incorporar pruebas de regresión para comprobar que agregar o modificar propiedades en la solicitud no permite alterar el precio final.

7. CVSS aproximado

CVSS v3.1: 6.5 — Medio (estimación preliminar).

Vector orientativo: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N`

Esta estimación presupone que el atacante necesita una cuenta autenticada y que la manipulación produce un impacto alto sobre la integridad de las transacciones. La puntuación debe revisarse según los requisitos de acceso y el impacto real en el sistema evaluado.

8. Prioridad

Alta para corrección en el flujo de checkout.

Se recomienda corregir esta condición antes de desplegar la aplicación en producción, debido al posible impacto económico de aceptar descuentos no autorizados.

9. Resultado

El laboratorio de PortSwigger Web Security Academy fue resuelto satisfactoriamente mediante la manipulación del porcentaje de descuento durante el proceso de checkout.

La prueba se realizó exclusivamente en un entorno educativo autorizado. El resultado demuestra el comportamiento vulnerable dentro de ese laboratorio y no implica que otros sistemas presenten la misma condición.